BREACHSIEVE - Vulnerability Assessment Report

Target: https://google.com | Date: 2026-10-18 07:52:05 UTC

Risk Score	Critical	High	Medium	Low	False Positives	Novel Patterns
10.0	**1**	**0**	**0**	**0**	**2**	**0**

Scope & Authorization Record

Target URL	https://google.com
Scan Mode	PASSIVE (Active Confirmed: 0)
Authorization Status	CONFIRMED - Explicit authorization granted by operator
Authorized At	2026-10-18T07:51:27.246818+00:00
In-Scope Rules	https://google.com google.com *.google.com
Out-of-Scope Rules	None

Confirmed Vulnerability Findings (1)

[BS-FIND-002] Strict-Transport-Security Header Not Set - **Critical (CVSS: 10.0)**

CWE: CWE-319 | **OWASP:** A02:2021-Cryptographic Failures | **MITRE:** T1557
URL: https://google.com
Description: HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
Gemini AI Verdict: [CONFIRMED] The request was made over HTTPS ('GET https://google.com HTTP/1.1') and received a response ('HTTP/1.1 301 Moved Permanently'). An examination of the response headers ('Location: https://www.google.com/', 'Server: gws', 'X-Frame-Options: SAMEORIGIN') confirms that the 'Strict-Transport-Security' header is completely missing from this HTTPS response.
Remediation: Configure the server to return the 'Strict-Transport-Security' header (e.g., 'Strict-Transport-Security: max-age=31536000; includeSubDomains; preload') across all HTTPS responses, including 301 redirects.

Remediation Summary Matrix

ID	Title	Severity	Actionable Fix
BS-FIND-002	Strict-Transport-Security Head	Critical	Configure the server to return the 'Strict-Transport-Security' header (e.g., 'Strict-Transpo

Methodology Note

This assessment was performed using automated OWASP ZAP scanning driven through its REST API, restricted to strictly verified in-scope allow-list rules. Alerts were triaged via Google Gemini API using evidence-based analysis to filter false positives and identify novel patterns. This automated assessment augments, not replaces, comprehensive manual security testing.